

Bug Bounty Platform - Relatório Técnico de Vulnerabilidade

BOLA (IDOR) no Endpoint de Comprovantes PIX

Pesquisador: Alice Martins

1. Descrição Técnica

O endpoint `/api/pix/comprovantes/{id}` falha ao implementar controle de acesso em nível de objeto (BOLA/IDOR). A API verifica se o token da sessão é válido, mas não realiza a checagem cruzada para garantir que o ID solicitado pertence ao dono do token.

2. Prova de Conceito (Passos para Reproduzir)

1. Autenticar no sistema com as credenciais do Usuário A e obter o Bearer Token.
2. Realizar uma transferência PIX para gerar um comprovante válido (ex: ID 1045).
3. Fazer uma requisição GET para `/api/pix/comprovantes/1046` (ID pertencente a outra transação).
4. A API retorna HTTP 200 OK com o JSON contendo os dados do pagador, recebedor e valor da transação do Usuário B.

3. Impacto

Exposição crítica de dados financeiros e PII. Permite que um agente malicioso autenticado realize a raspagem (scraping) do histórico de transações iterando sequencialmente os identificadores.